

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Sales POD Invoice Intelligence Platform

Official Project ID: Sales_POD_Invoice_Intelligence_Platform

Assessment Type: Internal VAPT / Application Security Assessment

NOT an independent third-party certification

Organization: Mediola / Globalspace (Internal Security Assessment)

Assessment Date: 2026-09-22

Report Version: 1.1

Classification: CONFIDENTIAL

This report presents evidence-based findings only. Items that could not be tested are explicitly marked Not Tested / Not Applicable / Requires Authenticated Access. No vulnerabilities, CVSS scores, ports, or scan results have been fabricated.

1. Confidentiality Notice

This document contains confidential security assessment information. Distribution is restricted to authorized personnel of the client organization and the assessing team. Do not publish externally. Secrets discovered during assessment are redacted.

2. Document Details

Document Title	Vulnerability Assessment & Penetration Testing (VAPT) Report
Project (Official ID)	Sales_POD_Invoice_Intelligence_Platform
Project (Human-Readable)	Sales POD Invoice Intelligence Platform
Version	1.1
Date	2026-09-22
Classification	CONFIDENTIAL
Authoring Party	Internal Application Security Assessment (Mediola / Globalspace)
Independent Third-Party Certification	No

3. Document History

Version	Date	Description
1.0	2026-09-22	Initial evidence-based internal VAPT report

4. Table of Contents

- 5. Executive / Project Summary
- 6. Assessment Objectives
- 7. Scope
- 8. Out-of-Scope Items
- 9. Assessment Methodology
- 10. Architecture Overview
- 11. Testing Environment
- 12. Tools Used
- 13. Security Strengths
- 14. Vulnerability Summary
- 14b. QA Severity Review
- 15. OWASP Top 10 Assessment
- 16. Detailed Technical Findings
- 17. Automated Scanning Results
- 18. Open Port Information
- 19. Dependency / SAST Results
- 20. Risk Definitions
- 21. Remediation Summary
- 22. Retest Recommendations

23. Disclaimer

5. Executive / Project Summary

An internal Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted against the Sales POD Invoice Intelligence Platform (Sales_POD_Invoice_Intelligence_Platform) stack as deployed on Azure host 135.235.16.138. Testing combined reconnaissance, configuration review, static analysis of Laravel/PHP and related service surfaces, safe unauthenticated dynamic probing of web/API/BI endpoints, Nmap port scanning, OpenSSL TLS checks, and npm dependency audit.

Confirmed and potential findings total **15** items. Severity distribution:

Severity	Count
Critical	0
High	0
Medium	7
Low	5
Informational	3

Priority remediate (Medium): unauthenticated /test-email (metadata + mail trigger); public phpinfo(); APP_ENV=local enabling Horizon SPA access; world-readable .env (local only — not HTTP); unauthenticated QR Extractor extract/stats (Swagger alone is not High).

Coverage statement: This assessment was conducted using the tools and techniques identified in the report. Areas marked Not Tested were outside the performed assessment and should not be interpreted as security validation.

Authentication limitation: Authenticated authorization testing, including IDOR/BOLA and privilege escalation testing, was not performed because authorized dual-user test accounts were not available. IDOR, BOLA, privilege escalation, horizontal/vertical access control, and authenticated file access remain **NOT TESTED** and must not be interpreted as passed.

HTTP evidence labeling: Captured HTTP Request/Response Evidence (curl). NOT Burp Suite screenshots. NOT OWASP ZAP alerts.

6. Assessment Objectives

- Identify security weaknesses in web/API/BI invoice processing components
- Validate authentication, authorization, and configuration controls where accessible
- Assess file-processing and BI/OCR service exposure
- Produce an evidence-backed client-ready report without fabricated results

7. Scope

- https://zydus.mediola.in/pod_dev/ (Laravel web/API application)
- <https://qr-extract.mediola.in> (E-Invoice QR Extractor FastAPI)
- <https://zydus-py.mediola.in> (Python invoice processing API)
- Host 135.235.16.138 (Azure VM) — limited port scan
- Local source/configuration review under /var/www/html/pod_dev
- Architecture reference ZIP under /var/www/html/api/

8. Out-of-Scope Items

- Destructive attacks against production data
- Authenticated dual-user IDOR matrix (no dedicated test accounts authorized)
- Malware upload / decompression bombs
- Social engineering / phishing
- Physical security
- Extraction of proprietary AI model weights
- Active exploitation beyond harmless PoC

Explicitly Not Tested / Tool Unavailable:

- Authenticated file-upload abuse (requires authorized test credentials)
- Cross-user IDOR / BOLA on invoices/batches/files (requires User A / User B accounts)
- Horizontal and vertical privilege escalation (authenticated)
- Authenticated file access controls between users
- OWASP ZAP active scan (tool not available)
- Burp Suite (tool not available)
- Nikto (tool not available)
- testssl.sh full suite (tool not available; openssl protocol checks performed)
- Nuclei / Semgrep / Bandit / Trivy (tools not available)
- Composer audit (composer audit command not defined / unavailable)
- SSRF through document/invoice processing
- QR Extractor resource-exhaustion / large-file abuse
- Rate-limit validation on /test-email (no sustained probing)

9. Assessment Methodology

Methodology followed OWASP Testing Guide principles: architecture discovery; passive and active reconnaissance; configuration and source review; controlled dynamic testing; dependency scanning; manual verification before confirming findings; CVSS 3.1 scoring based on observed exploitability.

10. Architecture Overview

The assessed system comprises: (1) Laravel 12 / PHP 8.2 web and REST API application under /var/www/html/pod_dev served at https://zydus.mediola.in/pod_dev/; (2) Sanctum token + session authentication with Spatie roles/permissions; (3) database-backed queues with Laravel Horizon; (4) external HTTPS AI/OCR services at qr-extract.mediola.in and zydus-py.mediola.in; (5) Apache 2.4.52 on Ubuntu; (6) MySQL/Redis bound such that they appear filtered from the public internet. An architecture ZIP was present under /var/www/html/api/ and was used as a reference inventory source.

11. Testing Environment

Primary URL: https://zydus.mediola.in/pod_dev/

API base: https://zydus.mediola.in/pod_dev/api

Host: 135.235.16.138

Assessment date: 2026-09-22

Mode: Read-only / safe probing against live deployment; no intentional destructive payloads.

12. Tools Used

Actually used:

- Nmap 7.80 — Port/service enumeration
- curl / openssl — HTTP header, TLS, endpoint probing — Captured HTTP Request/Response Evidence (not Burp/ZAP)
- Manual source-code review — Static analysis of routes, auth, config
- npm audit — Node dependency vulnerability scan
- PHP runtime inspection — Environment confirmation

Not used (unavailable / not executed):

- Burp Suite
- OWASP ZAP
- Nikto
- testssl.sh
- Nuclei
- Semgrep
- Bandit
- Trivy
- composer audit

OWASP ZAP was not used. Burp Suite was not used. Nikto was not used. Request/response blocks are Captured HTTP Request/Response Evidence from curl — NOT Burp Suite screenshots and NOT ZAP alerts.

13. Security Strengths

The following controls were verified with evidence during this assessment:

STR-001 — APP_DEBUG disabled in runtime

Evidence: APP_DEBUG=false in .env (evidence/21_app_config_redacted.txt)

STR-002 — Sanctum authentication enforced on sampled protected API routes

Evidence: Unauthenticated probes returned HTTP 401 (evidence/16_unauth_protected_endpoints.txt). Note: this does NOT validate object-level authorization (IDOR/BOLA Not Tested).

STR-003 — Web login rate limiting present

Evidence: LoginRequest::ensureIsNotRateLimited with 5 attempts (evidence/13b_login_request_rate.txt)

STR-004 — Session cookie flags Secure + HttpOnly

Evidence: evidence/30_cookie_flags.txt

STR-005 — Sensitive path exposure blocked for .env and .git over HTTP

Evidence: HTTP 404 for /.env and /.git (evidence/06_sensitive_path_probes.txt)

STR-006 — Storage directory not listable via web

Evidence: HTTP 403 for /storage/ (evidence/17_storage_dir.txt)

STR-007 — TLS 1.2 and 1.3 only (TLS 1.0/1.1 not negotiated in openssl checks)

Evidence: tls/04_protocols.txt

STR-008 — MySQL and Redis filtered from public internet

Evidence: nmap/public_ports.txt — 3306/6379 filtered externally

STR-009 — Password hashing uses bcrypt (Laravel Hash)

Evidence: evidence/10_password_hashing.txt

STR-010 — API login does not distinguish invalid user vs invalid password

Evidence: Uniform HTTP 401 Invalid credentials (evidence/15_account_enumeration.txt)

14. Vulnerability Summary

Severity	Count
Critical	0
High	0
Medium	7
Low	5
Informational	3

ID	Vulnerability	Severity	CVSS	OWASP	Status
VAPT-001	Unauthenticated /test-email Endpoint Triggers Mail and Discloses User/Mail Metadata	Medium	6.5	A01, A04, A05	Confirmed
VAPT-002	Public phpinfo() Endpoint — Configuration Information Disclosure	Medium	5.3	A05	Confirmed

VAPT-003	APP_ENV=local Causes Horizon Authorization Bypass — Unauthenticated SPA Access	Medium	6.5	A01, A05	Confirmed
VAPT-004	World-Readable .env File Permissions (Local Filesystem) — Not HTTP-Exposed	Medium	5.5	A05	Confirmed
VAPT-005	QR Extractor API Unauthenticated Access (Docs Public; Extract/Stats Reachable Without Auth)	Medium	6.5	A01, A04, A05	Confirmed
VAPT-006	Missing HTTP Security Headers	Low	3.1	A05	Confirmed
VAPT-007	Unauthenticated Test Routes May Disclose Business Data (Static Confirmed; Dynamic Partial)	Medium	6.5	A01, A05	Potential
VAPT-008	CORS Allowed Origins Set to Wildcard (*)	Low	3.1	A05	Confirmed
VAPT-009	API Login (/session/create) Lacks Application Rate Limiting	Medium	5.3	A07	Confirmed
VAPT-010	Server Version Disclosure via Server Header	Low	3.1	A05	Confirmed
VAPT-011	API Login Logs Full Request Including Password	Low	3.8	A07, A09	Confirmed
VAPT-012	SESSION_ENCRYPT Disabled	Low	3.1	A05	Confirmed
VAPT-013	npm Dependency Advisories (browserslist High advisory, postcss-selector-parser Low) — Runtime Exploitability Not Demonstrated	Informational	0.0	A06	Informational
VAPT-014	Zydu Python API Publicly Reachable (Banner Only; Full Auth Matrix Not Tested)	Informational	0.0	A05	Informational
VAPT-015	SSH Service Exposed on Public Interface	Informational	0.0	A05	Informational

Figure — Vulnerability Summary Table (from confirmed assessment evidence)

14b. QA Severity Review

Final severities were revalidated against evidence. Findings were not kept High to meet a target count.

Finding	Prior Sev	Prior CVSS	Evidence Supports?	Final Sev	Final CVSS
VAPT-001	High	7.3	No — adjusted	Medium	6.5
VAPT-002	High	7.5	No — adjusted	Medium	5.3
VAPT-003	High	7.5	No — adjusted	Medium	6.5
VAPT-004	High	7.8	No — adjusted	Medium	5.5
VAPT-005	High	7.3	No — adjusted	Medium	6.5
VAPT-006	Medium	5.3	No — adjusted	Low	3.1
VAPT-007	Medium	6.5	Yes	Medium	6.5
VAPT-008	Medium	5.3	No — adjusted	Low	3.1

VAPT-009	Medium	5.3	Yes	Medium	5.3
VAPT-010	Low	3.1	Yes	Low	3.1
VAPT-011	Low	3.8	Yes	Low	3.8
VAPT-012	Low	3.1	Yes	Low	3.1
VAPT-013	Information al	0.0	Yes	Information al	0.0
VAPT-014	Information al	0.0	Yes	Information al	0.0
VAPT-015	Information al	0.0	Yes	Information al	0.0

Figure — QA Severity Review (v1.1)

15. OWASP Top 10 Assessment

OWASP	Category	Status	Notes / Finding IDs
A01	Broken Access Control	FOUND	VAPT-001, VAPT-003, VAPT-005, VAPT-007
A02	Cryptographic Failures	NOT FOUND	TLS1.2/1.3 only observed; session cookies Secure+HttpOnly verified. SESSION_ENCRYPT=false is Low hardening (VAPT-012), not a cryptographic failure class confirmation.
A03	Injection	NOT TESTED	Parameterized Eloquent usage observed statically; authenticated injection tests not executed.
A04	Insecure Design	FOUND	VAPT-001, VAPT-005
A05	Security Misconfiguration	FOUND	VAPT-002, VAPT-003, VAPT-004, VAPT-006, VAPT-008, VAPT-010, VAPT-014, VAPT-015
A06	Vulnerable and Outdated Components	FOUND	Informational — build-tool advisories; runtime exploitability not demonstrated
A07	Identification and Authentication Failures	FOUND	VAPT-009, VAPT-011
A08	Software and Data Integrity Failures	NOT TESTED	—
A09	Security Logging and Monitoring Failures	FOUND	VAPT-011
A10	SSRF	NOT TESTED	Document-processing SSRF not dynamically tested without authorized upload credentials.

16. Detailed Technical Findings

VAPT-001: Unauthenticated /test-email Endpoint Triggers Mail and Discloses User/Mail Metadata

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Confirmed
OWASP	A01, A04, A05
Affected Component	GET https://zydus.mediola.in/pod_dev/test-email (routes/web.php, outside auth middleware)

Description

The route GET /test-email is registered without authentication. An unauthenticated request returned HTTP 200 with success=true, recipient email/name, and mail_config (mailer/from). Source code shows Mail::to is hardcoded to an internal address; query parameters email and user_id control which user identity is resolved and returned in JSON (user enumeration/metadata disclosure). No rate limiting was identified on this route; sustained abuse was Not Tested.

Business Impact

Privacy exposure of user contact details; nuisance/load on internal mailbox and SMTP; reconnaissance aid for phishing.

Technical Impact

Missing authentication on a mail-triggering debug route; user metadata disclosure in JSON responses.

CVSS Rationale

Unauthenticated network access discloses user email/name and mail-from metadata and can trigger outbound SMTP to a hardcoded internal recipient. Not scored as High because evidence shows Mail::to is hardcoded (not an open relay to arbitrary attacker-controlled addresses). Availability impact via sustained spam was Not Tested.

Root Cause

Debug/test route registered without auth middleware in production web routes

Expected Result

HTTP 401/403 or route absent in production

Actual Result

HTTP 200; application reported email sent; user/mail metadata disclosed. SMTP delivery to Internet-arbitrary recipients not demonstrated.

Recommendation

Remove /test-email from production. Restrict mail tests to artisan or admin-only authenticated endpoints. Do not return user emails in unauthenticated responses. Add rate limiting if any test mail endpoint must remain.

Steps to Reproduce

1. Without authentication, request GET https://zydus.mediola.in/pod_dev/test-email
2. Observe HTTP 200 JSON confirming mail send attempt and disclosing recipient/mail_config
3. Optionally review routes/web.php and note Mail::to is hardcoded; email/user_id query params affect returned recipient metadata

Request (sanitized)

```
GET /pod_dev/test-email HTTP/1.1
Host: zydus.mediola.in
```

(no Authentication / Cookie required)

Response (sanitized)

HTTP/1.1 200 OK

Content-Type: application/json

```
{"success":true,"message":"Test email sent successfully!","recipient":{"email":"[REDACTED]","name":"[REDACTED]"},"mail_config":{"mailer":"smtp","from":"[REDACTED]"}}
```

Evidence Files

- evidence/26_test_routes_unauth.txt
- evidence/26b_test_email_body.txt
- evidence/26c_test_routes_source.txt

References

- CWE-306: Missing Authentication for Critical Function
- OWASP ASVS V4.1 Access Control

VAPT-002: Public phpinfo() Endpoint — Configuration Information Disclosure

Severity	Medium
CVSS v3.1 Score	5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	GET https://zydus.mediola.in/pod_dev/phpinfo.php (public/phpinfo.php)

Description

phpinfo.php is publicly accessible without authentication (HTTP 200, ~87KB). Confirmed disclosure includes PHP 8.2.30, DOCUMENT_ROOT, SERVER_SOFTWARE, Loaded Configuration File, disable_functions, open_basedir, and an Environment-related section. Evidence flags: contains__ENV=False, contains_HTTP_COOKIE=False — no confirmed dump of application secrets/credentials from this endpoint in the collected analysis.

Business Impact

Accelerates targeted follow-on attacks; does not by itself demonstrate account takeover.

Technical Impact

Confidentiality of environment/configuration details (Low as demonstrated).

CVSS Rationale

Unauthenticated disclosure of PHP/runtime configuration and paths aids reconnaissance. Evidence analysis recorded Environment section presence but __ENV and HTTP_COOKIE dumps as false — credentials in phpinfo were not confirmed. Scored Confidentiality Low, not High.

Root Cause

Diagnostic file left in public web root

Expected Result

HTTP 404 or access denied

Actual Result

HTTP 200 with phpinfo(); configuration/path disclosure confirmed; credential dump not confirmed in analysis flags

Recommendation

Delete public/phpinfo.php from all reachable environments. Block diagnostic scripts at the web server.

Steps to Reproduce

1. Request https://zydus.mediola.in/pod_dev/phpinfo.php without authentication
2. Observe full phpinfo HTML output

Request (sanitized)

```
GET /pod_dev/phpinfo.php HTTP/1.1
Host: zydus.mediola.in
```

Response (sanitized)

```
HTTP/1.1 200 OK
Content-Type: text/html

<title>PHP 8.2.30 - phpinfo()</title> ... (~87KB phpinfo page)
```

Evidence Files

- evidence/07_phpinfo_analysis.txt
- evidence/26_test_routes_unauth.txt

References

- CWE-200: Exposure of Sensitive Information
- OWASP A05 Security Misconfiguration

VAPT-003: APP_ENV=local Causes Horizon Authorization Bypass — Unauthenticated SPA Access

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A01, A05
Affected Component	GET /pod_dev/horizon ; Horizon auth callback; APP_ENV=local (APP_DEBUG=false)

Description

Two related but distinct observations: (1) APP_ENV=local on a publicly reachable deployment; (2) Laravel Horizon authorizes requests when app()->environment('local') is true, bypassing the admin-only viewHorizon gate. Dynamically, unauthenticated GET /horizon returned the Horizon SPA (~1.7MB) referencing Jobs/Queues UI. GET /horizon/api/batches returned HTTP 200 {"batches":[]}. Stats/workload/jobs/recent returned HTTP 500 generic errors. APP_DEBUG remains false.

Business Impact

Operations tooling exposure; potential future disclosure if queues contain sensitive payloads (not demonstrated here).

Technical Impact

Broken access control on Horizon SPA due to local-environment auth bypass.

CVSS Rationale

Evidence links APP_ENV=local to Horizon auth bypass (framework: Gate OR environment local). Unauthenticated Horizon SPA (HTTP 200) and batches API (HTTP 200 empty) confirmed. APP_DEBUG=false (separate). Most Horizon API probes returned HTTP 500 — sensitive job payload disclosure and administrative actions (pause/retry/purge) were NOT demonstrated. Severity reflects confirmed unauthenticated access to the ops UI shell with limited demonstrated data exposure.

Root Cause

APP_ENV=local enables Horizon local-environment authorization bypass on a publicly reachable host

Expected Result

Login required / HTTP 403 for non-admin in non-local production

Actual Result

Horizon SPA accessible without authentication; limited API data returned; admin actions not demonstrated

Recommendation

Set APP_ENV=production. Ensure Horizon uses admin gate only. IP-restrict /horizon. Retest that unauthenticated access is denied and that authenticated non-admins cannot access Horizon.

Steps to Reproduce

1. Confirm APP_ENV=local and APP_DEBUG=false from configuration evidence
2. Open https://zydus.mediola.in/pod_dev/horizon without login — observe SPA load
3. Probe /horizon/api/batches and other API paths; record actual status codes

Request (sanitized)

```
GET /pod_dev/horizon HTTP/1.1
Host: zydus.mediola.in
```

(no auth)

GET /pod_dev/horizon/api/batches HTTP/1.1

Response (sanitized)

horizon → HTTP 200 Horizon SPA HTML

batches → HTTP 200 {"batches":[]}

other horizon/api/* probed → HTTP 500 generic error JSON

Evidence Files

- evidence/20_app_env.txt
- evidence/08_horizon_analysis.txt
- evidence/08b_horizon_api_probes.txt
- evidence/08c_horizon_gate_code.txt

References

- Laravel Horizon Authorization
- CWE-306

VAPT-004: World-Readable .env File Permissions (Local Filesystem) — Not HTTP-Exposed

Severity	Medium
CVSS v3.1 Score	5.5
CVSS Vector	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	/var/www/html/pod_dev/.env (mode 775, owner azureuser:azureuser)

Description

Owner: azureuser; Group: azureuser; Mode: 775 (-rwxrwxr-x). Other (world) has read+execute; group has write. Web server processes run as www-data; world-read allows www-data and any other local account to read secrets. HTTP probes to /.env and /.env.example returned 404 (not publicly downloadable). This finding is local privilege/access exposure only.

Business Impact

If another local account or compromised low-privilege process exists, full credential disclosure is possible.

Technical Impact

Secret confidentiality failure on filesystem (local).

CVSS Rationale

Mode 775 grants other-read. Any local OS user can read application secrets. Attack vector is Local (AV:L), not Network. HTTP GET /.env returned 404 — publicly downloadable .env is NOT present and must not be claimed. Integrity/Availability not demonstrated via this permission alone.

Root Cause

Insecure file mode on secrets file

Expected Result

Permissions 600 or 640; HTTP still 404

Actual Result

775 world-readable; HTTP 404 (good for web exposure)

Recommendation

chmod 600 .env (ensure the PHP/Apache user can still read as required via ownership/ACL). Prefer Azure Key Vault. Do not treat this as a public HTTP secret leak.

Steps to Reproduce

1. stat -c '%a %U:%G %n' /var/www/html/pod_dev/.env
2. curl -skI https://zydus.mediola.in/pod_dev/.env — expect 404

Request (sanitized)

```
Filesystem: stat .env
HTTP: GET /pod_dev/.env → 404 (separate check; not vulnerable to public download)
```

Response (sanitized)

```
stat: 775 azureuser:azureuser
HTTP /.env: 404
```

Evidence Files

- evidence/18_env_file_perms.txt
- evidence/06_sensitive_path_probes.txt

References

- CWE-732: Incorrect Permission Assignment for Critical Resource

VAPT-005: QR Extractor API Unauthenticated Access (Docs Public; Extract/Stats Reachable Without Auth)

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Confirmed
OWASP	A01, A04, A05
Affected Component	https://qr-extract.mediola.in — /docs, /openapi.json, /extract-qr, /stats, /health

Description

Component breakdown: (A) /docs Swagger UI and /openapi.json are publicly reachable. (B) POST /extract-qr without credentials returned HTTP 422 Field required (proves auth not required). (C) OpenAPI lists /extract-qr and /batch-extract. (D) GET /stats returned load/statistics/configuration JSON without auth — no invoice field data in this response. (E) No administrative control plane identified beyond service stats. (F) Large-file / concurrency abuse Not Tested.

Business Impact

Unauthorized use of processing capacity; API surface reconnaissance.

Technical Impact

Missing authentication on AI/OCR-adjacent service; documentation and metrics exposure.

CVSS Rationale

Separated impacts: (A) Public Swagger/OpenAPI — Low/Info alone; (B) Unauthenticated API — confirmed (POST /extract-qr returns 422 validation, not 401); (C) Extraction functionality exists per OpenAPI; successful extraction of sensitive invoice content Not deeply demonstrated; (D) /stats returns operational metrics (Low sensitivity); (E) Admin functions not observed; (F) Resource exhaustion Not Tested. Combined unauthorized service use + recon scored Medium, not High.

Root Cause

Service deployed without auth middleware / network allowlisting

Expected Result

Authentication and/or private network restriction; docs disabled in production

Actual Result

Unauthenticated docs, extract endpoint, and stats accessible

Recommendation

Require API key or mTLS; IP-allowlist Laravel app servers; disable /docs and /openapi.json in production; rate-limit extract endpoints; retest resource exhaustion separately.

Steps to Reproduce

1. Open https://qr-extract.mediola.in/docs (Swagger UI loads)
2. POST https://qr-extract.mediola.in/extract-qr without credentials — observe 422 not 401
3. GET https://qr-extract.mediola.in/stats — observe 200 metrics

Request (sanitized)

```
POST /extract-qr HTTP/1.1
Host: qr-extract.mediola.in
(no Authorization)

GET /stats HTTP/1.1
```

Host: qr-extract.mediola.in

Response (sanitized)

extract-qr → HTTP 422 {"detail":[{"msg":"Field required",...}]}

stats → HTTP 200 operational metrics JSON (no invoice payloads in captured response)

Evidence Files

- evidence/14d_qr_openapi.json
- evidence/27_qr_extract_unauth_post.txt
- evidence/28_qr_stats_unauth.txt

References

- OWASP API Security Top 10
- CWE-306

VAPT-006: Missing HTTP Security Headers

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	https://zydus.mediola.in/pod_dev/ (Apache responses)

Description

Responses lack Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy.

Business Impact

Increased residual risk of clickjacking/MIME confusion if other flaws exist.

Technical Impact

Security headers absent.

CVSS Rationale

Missing headers are defense-in-depth. Clickjacking-class impact requires user interaction and higher attack complexity without additional flaws; scored Low (3.1).

Root Cause

No global security header middleware / Apache config

Expected Result

Security headers present per OWASP Secure Headers guidance

Actual Result

Headers missing

Recommendation

Add HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

Steps to Reproduce

1. curl -skI https://zydus.mediola.in/pod_dev/login
2. Verify listed security headers are absent

Request (sanitized)

```
GET /pod_dev/login HTTP/1.1
Host: zydus.mediola.in
```

Response (sanitized)

```
HTTP/1.1 200 OK
Server: Apache/2.4.52 (Ubuntu)
(no HSTS/CSP/XFO/XCTO)
```

Evidence Files

- evidence/05_security_headers_analysis.txt

References

- OWASP Secure Headers Project

VAPT-007: Unauthenticated Test Routes May Disclose Business Data (Static Confirmed; Dynamic Partial)

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Status	Potential
OWASP	A01, A05
Affected Component	/test-hospital-performance, /test-employee-performance/{employeeCode}

Description

web.php registers unauthenticated test routes that query Employee/PodTrackerService and return employee names, codes, and sample performance data. Dynamic probe to /test-hospital-performance returned HTTP 000 (timeout) during assessment.

Business Impact

Business-sensitive analytics disclosure if reachable.

Technical Impact

Active debug code without authentication.

CVSS Rationale

Source shows unauthenticated routes returning employee performance samples (C:H if data returns). Dynamic GET /test-hospital-performance timed out (000) — Potential, not fully dynamically confirmed.

Root Cause

Debug routes left in production routing table

Expected Result

Routes absent or authenticated

Actual Result

Routes present without auth in source; one timed out dynamically

Recommendation

Remove all /test-* routes from production immediately.

Steps to Reproduce

1. Review routes/web.php test route closures
2. Attempt unauthenticated GET (may timeout under load)

Request (sanitized)

```
GET /pod_dev/test-hospital-performance HTTP/1.1
```

Response (sanitized)

```
Dynamic: HTTP 000 timeout. Static: intended JSON with employee and sample_data.
```

Evidence Files

- evidence/26c_test_routes_source.txt
- evidence/26_test_routes_unauth.txt

References

- CWE-489: Active Debug Code

VAPT-008: CORS Allowed Origins Set to Wildcard (*)

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	config/cors.php

Description

allowed_origins is ['*'] for api/* and sanctum/csrf-cookie. supports_credentials is false.

Business Impact

Hardening gap for browser-based API consumers.

Technical Impact

Any origin may read non-credentialed CORS responses for configured paths.

CVSS Rationale

Wildcard CORS on api/* with supports_credentials=false. Browser credentialed cross-origin abuse is limited; residual risk if bearer tokens are stolen via XSS elsewhere (not demonstrated).

Root Cause

Permissive CORS configuration

Expected Result

Explicit allowlist of trusted origins

Actual Result

Wildcard *

Recommendation

Replace * with explicit mobile/web app origins.

Steps to Reproduce

1. Inspect config/cors.php

Request (sanitized)

N/A — configuration review

Response (sanitized)

'allowed_origins' => ['*']; 'supports_credentials' => false

Evidence Files

• evidence/22b_cors_full.txt

References

• OWASP HTML5 Security Cheat Sheet — CORS

VAPT-009: API Login (/session/create) Lacks Application Rate Limiting

Severity	Medium
CVSS v3.1 Score	5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Confirmed
OWASP	A07
Affected Component	POST /api/session/create → AuthenticatedSessionController::apiLogin

Description

apiLogin validates credentials without ensureIsNotRateLimited. Web form login uses LoginRequest with 5-attempt throttle. Adjacent routes (handoff exchange, app-version refresh) use throttle:30,1 but session/create does not.

Business Impact

Increased account compromise risk under automated attack.

Technical Impact

Missing auth brute-force control on API login.

CVSS Rationale

Route POST /api/session/create has no throttle middleware; apiLogin lacks RateLimiter used by web LoginRequest. Destructive credential stuffing was not executed.

Root Cause

Inconsistent auth hardening between web and API

Expected Result

Shared rate limiting on all authentication endpoints

Actual Result

API login missing RateLimiter / route throttle

Recommendation

Apply throttle middleware and/or RateLimiter to apiLogin; monitor failures.

Steps to Reproduce

1. Review routes/api.php session/create
2. Compare apiLogin with LoginRequest rate limiting

Request (sanitized)

POST /api/session/create (email/password) – no route throttle observed

Response (sanitized)

N/A – code-level confirmation; destructive brute-force not executed

Evidence Files

- evidence/25_api_login_logs_password.txt
- evidence/13b_login_request_rate.txt

References

- OWASP A07
- CWE-307

VAPT-010: Server Version Disclosure via Server Header

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	Apache HTTP responses

Description

HTTP responses include Server: Apache/2.4.52 (Ubuntu).

Business Impact

Negligible alone.

Technical Impact

Information disclosure.

CVSS Rationale

Server: Apache/2.4.52 (Ubuntu) aids reconnaissance only.

Root Cause

Default Apache ServerTokens

Expected Result

Server token minimized

Actual Result

Full version disclosed

Recommendation

Set ServerTokens Prod and ServerSignature Off.

Steps to Reproduce

1. curl -skI https://zydus.mediola.in/pod_dev/login

Request (sanitized)

```
GET /pod_dev/login
```

Response (sanitized)

```
Server: Apache/2.4.52 (Ubuntu)
```

Evidence Files

- evidence/05_security_headers_analysis.txt
- nmap/public_ports.txt

References

- CWE-200

VAPT-011: API Login Logs Full Request Including Password

Severity	Low
CVSS v3.1 Score	3.8
CVSS Vector	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Status	Confirmed
OWASP	A07, A09
Affected Component	AuthenticatedSessionController::apiLogin — Log::info(\$request->all())

Description

Before authentication, apiLogin logs the entire request payload including plaintext password.

Business Impact

Credential exposure if logs are broadly accessible.

Technical Impact

Sensitive data in logs.

CVSS Rationale

Log::info(\$request->all()) persists passwords; exploitation requires log access (local/privileged).

Root Cause

Debug logging in authentication path

Expected Result

Never log passwords

Actual Result

Full request including password logged at info level

Recommendation

Remove the log line; scrub historical logs; force password resets if logs were broadly accessible.

Steps to Reproduce

1. Open AuthenticatedSessionController::apiLogin
2. Observe Log::info(\$request->all())

Request (sanitized)

N/A – source code

Response (sanitized)

Log::info(\$request->all()); // includes password

Evidence Files

- evidence/25_api_login_logs_password.txt

References

- CWE-532

VAPT-012: SESSION_ENCRYPT Disabled

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
OWASP	A05
Affected Component	SESSION_ENCRYPT=false in .env

Description

Laravel session encryption is disabled while session driver is database.

Business Impact

Defense-in-depth gap.

Technical Impact

Reduced session confidentiality at rest in DB.

CVSS Rationale

Unencrypted session payloads in DB increase impact if DB compromised; cookies remain HttpOnly+Secure.

Root Cause

Configuration hardening gap

Expected Result

SESSION_ENCRYPT=true in production

Actual Result

false

Recommendation

Enable SESSION_ENCRYPT=true and re-test sessions.

Steps to Reproduce

1. Inspect SESSION_ENCRYPT in environment evidence

Request (sanitized)

N/A

Response (sanitized)

SESSION_ENCRYPT=false

Evidence Files

- evidence/21_app_config_redacted.txt

References

- Laravel Session Encryption

VAPT-013: npm Dependency Advisories (browserslist High advisory, postcss-selector-parser Low) — Runtime Exploitability Not Demonstrated

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	N/A
Status	Informational
OWASP	A06
Affected Component	package.json / node_modules (dev-heavy tree)

Description

npm audit reported browserslist <=4.28.6 (advisory severity High) and postcss-selector-parser 6.1.0-6.1.2 (Low). These are not confirmed reachable in the production request path.

Business Impact

Maintain SCA hygiene in CI.

Technical Impact

Known advisories in dependency tree.

CVSS Rationale

npm audit advisories exist; primarily frontend/build toolchain. Runtime exploitation against production HTTP service not demonstrated.

Root Cause

Outdated transitive frontend dependencies

Expected Result

No known vulnerable packages / documented exceptions

Actual Result

2 advisories; fixAvailable true; runtime exposure Needs Manual Verification

Recommendation

Update packages; re-run npm audit; do not treat advisory High as production CVSS High without runtime reachability.

Steps to Reproduce

1. Run npm audit in project root

Request (sanitized)

N/A

Response (sanitized)

npm audit metadata: high=1, low=1 (advisory severities)

Evidence Files

- deps/npm_audit.json
- deps/npm_audit_confirmed.txt

References

- <https://github.com/advisories/GHSA-c83g-rgw3-j3cx>
- <https://github.com/advisories/GHSA-w9m9-85wc-3x92>

VAPT-014: Zydus Python API Publicly Reachable (Banner Only; Full Auth Matrix Not Tested)

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	N/A
Status	Informational
OWASP	A05
Affected Component	https://zydus-py.mediola.in

Description

Service responds on /, /docs, /health, /predict, /api with 'Zydus Python API Server is running'. Full endpoint authorization matrix Not Tested.

Business Impact

Requires follow-up API testing.

Technical Impact

Incomplete coverage on this service.

CVSS Rationale

Service responds with generic running banner; functional extraction/auth matrix Not Tested.

Root Cause

Service exposure on public hostname

Expected Result

Private network only or authenticated API

Actual Result

Publicly reachable health/banner

Recommendation

Restrict to private VNet/IP allowlist; complete endpoint inventory in retest.

Steps to Reproduce

1. curl -sk https://zydus-py.mediola.in/

Request (sanitized)

```
GET / HTTP/1.1
Host: zydus-py.mediola.in
```

Response (sanitized)

```
HTTP/1.1 200 OK
Zydus Python API Server is running
```

Evidence Files

- evidence/29_zydus_py_health.txt
- evidence/29d_zydus_py_paths.txt

References

- OWASP API Security Top 10

VAPT-015: SSH Service Exposed on Public Interface

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	N/A
Status	Informational
OWASP	A05
Affected Component	135.235.16.138:22

Description

Nmap shows OpenSSH 8.9p1 Ubuntu on port 22 publicly open.

Business Impact

Reduce Internet SSH exposure as hardening.

Technical Impact

Attack surface for SSH if weak auth (Not Tested).

CVSS Rationale

Port 22 open with OpenSSH 8.9p1; no credential attacks performed; hardening Not Fully Tested.

Root Cause

Azure NSG allows 22/tcp from internet (inferred from scan reachability)

Expected Result

SSH limited by NSG to admin IPs

Actual Result

Publicly reachable SSH

Recommendation

Restrict SSH to bastion/VPN/admin IP allowlist; key-only auth.

Steps to Reproduce

- 1. Review nmap/public_ports.txt

Request (sanitized)

```
Nmap -sV -p 22 135.235.16.138
```

Response (sanitized)

```
22/tcp open ssh OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
```

Evidence Files

- nmap/public_ports.txt

References

- CIS Ubuntu Benchmark

17. Automated Scanning Results

Automated scanners were used only where available. Results below are actual outputs; manual verification was applied before promoting items to confirmed vulnerabilities.

17.1 Nmap

```
# Nmap 7.80 scan initiated Tue Sep 22 10:01:23 2026 as: nmap -sV -sT -Pn -T4 -p 22,80,443,3306,6379,8000,8001,8080,8443,9000 -oN /var/www/html/api/vapt_invoice_intelligence_engine/nmap/public_ports.txt 135.235.16.138
Nmap scan report for 135.235.16.138
Host is up (0.00069s latency).
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.52
443/tcp	open	ssl/http	Apache httpd 2.4.52 ((Ubuntu))
3306/tcp	filtered	mysql	
6379/tcp	filtered	redis	
8000/tcp	filtered	http-alt	
8001/tcp	filtered	vcom-tunnel	
8080/tcp	filtered	http-proxy	
8443/tcp	filtered	https-alt	
9000/tcp	filtered	cslistener	

Service Info: Host: zydus.mediola.in; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
 # Nmap done at Tue Sep 22 10:01:36 2026 -- 1 IP address (1 host up) scanned in 13.96 seconds

Figure 1 — Nmap Port Scan (public host)

17.2 OWASP ZAP / Burp Suite

Not Used. No OWASP ZAP scan was performed. No Burp Suite scan was performed. HTTP evidence is Captured HTTP Request/Response Evidence (curl) only.

17.3 TLS (OpenSSL)

```
=== zydus.mediola.in ===
tls1: 40A713B79E710000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_1: 4017D60516750000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_2: CONNECTED(00000005)
New, TLSv1.2, Cipher is ECDHE-ECDSA-AES256-GCM-SHA384
  Protocol  : TLSv1.2
  Cipher    : ECDHE-ECDSA-AES256-GCM-SHA384
tls1_3: CONNECTED(00000005)
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
  Protocol  : TLSv1.3
  Cipher    : TLS_AES_256_GCM_SHA384
  Protocol  : TLSv1.3
=== qr-extract.mediola.in ===
tls1: 40B7B9F89E780000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_1: 40D70C6A1B7A0000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_2: CONNECTED(00000005)
New, TLSv1.2, Cipher is ECDHE-ECDSA-AES256-GCM-SHA384
  Protocol  : TLSv1.2
  Cipher    : ECDHE-ECDSA-AES256-GCM-SHA384
tls1_3: CONNECTED(00000005)
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
=== zydus-py.mediola.in ===
```

```
tls1: 40C75FEF48710000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../
ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_1: 40474DF07F730000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../
ssl/statem/statem_lib.c:104:
CONNECTED(00000005)
New, (NONE), Cipher is (NONE)
tls1_2: CONNECTED(00000005)
New, TLSv1.2, Cipher is ECDHE-ECDSA-AES256-GCM-SHA384
    Protocol   : TLSv1.2
    Cipher     : ECDHE-ECDSA-AES256-GCM-SHA384
tls1_3: CONNECTED(00000005)
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
```

Figure 2 — TLS Protocol Negotiation Results

17.4 npm audit

```
browserslist: severity=high via=[{'source': 1153171, 'name': 'browserslist', 'dependency':
'browserslist', 'title': 'Browserslist: Unbounded memory growth (no cache eviction) via distinct
query results, leading to eventual OOM', 'url': 'https://github.com/advisories/GHSA-c83g-rgw3-j3cx',
'severity': 'high', 'cwe': ['CWE-770'], 'cvss': {'score': 7.5, 'vectorString': 'CVSS:3.1/AV:N/AC:L/
PR:N/UI:N/S:U/C:N/I:N/A:H'}, 'range': '<=4.28.6'}, {'source': 1153172, 'name': 'browserslist',
'dependency': 'browserslist', 'title': 'Browserslist: Uncaught crash / prototype write via
untrusted browserslist-stats.json custom stats (normalizeStats)', 'url': 'https://github.com/
advisories/GHSA-73wf-gq98-2v4g', 'severity': 'high', 'cwe': ['CWE-248', 'CWE-1321'], 'cvss': {
'score': 7.5, 'vectorString': 'CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H'}, 'range': '<=4.28.
6'}] range=<=4.28.6 fixAvailable=True
postcss-selector-parser: severity=low via=[{'source': 1153170, 'name': 'postcss-selector-parser',
'dependency': 'postcss-selector-parser', 'title': 'postcss-selector-parser allows denial of service
through uncontrolled AST recursion', 'url': 'https://github.com/advisories/GHSA-w9m9-85wc-3x92',
'severity': 'low', 'cwe': ['CWE-404'], 'cvss': {'score': 4.3, 'vectorString': 'CVSS:3.1/AV:N/AC:L/
PR:N/UI:R/S:U/C:N/I:N/A:L'}, 'range': '>=6.1.0 <6.1.3'}] range=6.1.0 - 6.1.2 fixAvailable=True
meta {'vulnerabilities': {'info': 0, 'low': 1, 'moderate': 0, 'high': 1, 'critical': 0, 'total': 2},
'dependencies': {'prod': 25, 'dev': 278, 'optional': 76, 'peer': 3, 'peerOptional': 0, 'total':
305}}
```

Figure 3 — npm audit summary

18. Open Port Information

Port	Proto	State	Service	Version
22	tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
80	tcp	open	http	Apache httpd 2.4.52
443	tcp	open	ssl/http	Apache httpd 2.4.52 ((Ubuntu))
3306	tcp	filtered	mysql	—
6379	tcp	filtered	redis	—
8000	tcp	filtered	http-alt	—
8001	tcp	filtered	vcom-tunnel	—
8080	tcp	filtered	http-proxy	—
8443	tcp	filtered	https-alt	—
9000	tcp	filtered	cslistener	—

Scan time: 2026-09-22 10:01:23 UTC. Only ports confirmed by Nmap are listed. Do not assume additional open ports.

19. Dependency / SAST Results

npm audit: 1 High (browserslist), 1 Low (postcss-selector-parser) — see VAPT-013 (Informational pending runtime verification). composer audit: Not Available. Semgrep/Bandit/Trivy/PHPStan security suite: Not Used. Manual SAST-equivalent review of authentication, CORS, Horizon gate, and test routes was performed.

20. Risk Definitions

Critical (9.0–10.0): Immediate compromise of critical assets likely.

High (7.0–8.9): Significant confidentiality/integrity impact with practical exploit path.

Medium (4.0–6.9): Meaningful risk requiring planned remediation.

Low (0.1–3.9): Limited impact or difficult exploit conditions.

Informational (0.0): Observation / hardening opportunity without demonstrated exploit.

21. Remediation Summary

1. Immediately remove or auth-protect /test-email, /test-hospital-performance, /test-employee-performance, and phpinfo.php
2. Set APP_ENV=production; verify Horizon requires admin authentication; IP-restrict /horizon
3. chmod 600 .env; review secret exposure; rotate credentials if logs/.env were broadly readable
4. Authenticate and IP-restrict qr-extract.mediola.in; disable Swagger in production
5. Add security headers (HSTS, CSP, XFO, XCTO); minimize Server header
6. Rate-limit apiLogin; remove Log::info(\$request->all()) password logging; scrub historical logs
7. Tighten CORS allowlist; enable SESSION_ENCRYPT
8. Update npm advisories; restrict SSH to admin IPs

22. Retest Recommendations

After remediation, retest all High/Medium findings with authenticated dual-user IDOR matrix, controlled upload security tests, ZAP/Burp authenticated crawl, full TLS suite (testssl.sh), and SCA (composer audit + npm audit + container scanning).

23. Disclaimer

This assessment was conducted internally as a security assessment of the Sales POD Invoice Intelligence Platform. The assessment is intended to identify security vulnerabilities and configuration weaknesses within the defined scope and should not be interpreted as a formal certification or independent third-party security certification.

The assessment results are based on the scope, testing methods, tools, access, and environment available during the assessment period. Areas identified as Not Tested or outside the defined scope have not been independently validated and should not be interpreted as having passed security testing.

This assessment was conducted using the tools and techniques identified in the report. Areas marked Not Tested were outside the performed assessment and should not be interpreted as security validation. Authenticated authorization testing, including IDOR/BOLA and privilege escalation testing, was not performed because authorized dual-user test accounts were not available. Findings reflect the state of systems at the time of testing (2026-09-22), report version 1.1. Security posture may change. All secrets in this report are redacted.